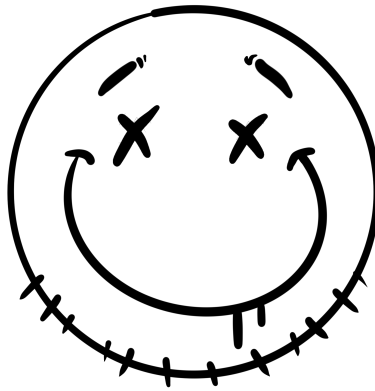




Remediation Plan

Keith Schoen

CSEC3755-001

Dr. Daniel Pittman

28 April 2026

Contents

1	Prioritized Remediation Roadmap	1
1.1	Findings Ranked by Risk	1
1.2	Remediation Order and Dependencies	2
1.3	Timeframe Summary	4
2	Remediation Details	7
2.1	Firewall Hardening (FW1–FW4)	7
2.2	F1 — Anonymous FTP Login	11
2.3	F2 — Cleartext HTTP Credential Transmission	13
2.4	F3 — FTP Cleartext Authentication	16
2.5	F4 — Deprecated TLS 1.0 and 1.1 on RDP	19
2.6	F5 — DCE/RPC Endpoint Enumeration	21
2.7	F6 — Weak SSH MAC Algorithms	24
3	Compensating Controls	26
3.1	Firewall Gaps (FW1–FW4): Before Hardening Is Applied	27
3.2	F1 and F3: Anonymous FTP and Cleartext FTP Auth	29
3.3	F2: Cleartext HTTP Credential Transmission	31
3.4	F4: Deprecated TLS on RDP	33
3.5	F5: DCE/RPC Endpoint Enumeration	35
3.6	Summary of Compensating Controls	36
4	Compliance Mapping	38
4.1	HIPAA Technical Safeguards Reference	38
4.2	Finding-to-Safeguard Mapping	40
4.3	Q3 Audit Readiness Checklist	44
4.4	Documentation for Compliance Demonstration	47

5	Resource Estimates	50
5.1	How to Read These Estimates	50
5.2	Personnel Skill Requirements	51
5.3	Immediate Window Estimates (0–7 Days)	52
5.4	Short-Term Window Estimates (8–30 Days)	54
5.5	Long-Term Window Estimates (31–90 Days)	55
5.6	Werkzeug Follow-On Task	56
5.7	Full Engagement Summary	56

1 Prioritized Remediation Roadmap

1.1 Findings Ranked by Risk

The table below presents all findings in descending composite risk order. Composite scores are derived from a weighted formula incorporating exploitability, impact, asset value, and HIPAA regulatory exposure:

$$\text{Composite} = \text{Exploitability} \times 0.25 + \text{Impact} \times 0.30 + \text{Asset Value} \times 0.25 + \text{HIPAA} \times 0.20$$

Firewall configuration gaps (FW1–FW4) are included as unscored findings given their role as a network-layer force multiplier on all host-level vulnerabilities.

ID	Severity	Finding	CVSS	Compos.	System(s)
F1	MEDIUM	Anonymous FTP login — confidential directory exposed	6.4	5.00	Ubuntu (.102)
F2	MEDIUM	Cleartext HTTP credential transmission	4.8	4.45	Ubuntu (.102)
F3	MEDIUM	FTP authenticated sessions over cleartext	4.8	3.95	Ubuntu (.102)
FW1	HIGH*	Firewall default ACCEPT policy on all chains	N/A	N/A	Router (.106)
FW2	HIGH*	Unrestricted inter-zone forwarding (all ports/protocols)	N/A	N/A	Router (.106)

ID	Severity	Finding	CVSS	Compos	System(s)
FW3	MEDIUM	No stateful inspection — no established/related tracking	N/A	N/A	Router (.106)
FW4	MEDIUM	Management services (SSH, Webmin) exposed on all interfaces	N/A	N/A	Router (.106)
F4	MEDIUM	Deprecated TLS 1.0/1.1 on RDP service	4.3	3.75	Windows (.105)
F5	MEDIUM	DCE/RPC endpoint enumeration — internal service map exposed	5.0	3.45	Windows (.105)
F6	LOW	Weak SSH MAC algorithms (umac-64) on both servers	2.6	2.50	Ubuntu, Windows
F7	LOW	TCP timestamp information disclosure	2.6	1.95	Ubuntu, Windows
F8	LOW	ICMP timestamp reply enabled	2.1	1.95	Ubuntu (.102)

* *FW1 and FW2 are unscored under the D1 composite model but are treated as High-equivalent given their role as network-layer prerequisites. With default ACCEPT and unrestricted forwarding in place, every host-level vulnerability is reachable without constraint.*

1.2 Remediation Order and Dependencies

Findings are grouped into three remediation windows based on risk severity and logical dependency. Dependencies are noted where the remediation of one finding is a prerequisite for, or is most efficiently addressed alongside, another.

Immediate Window (0–7 Days)

The firewall hardening items (FW1–FW4) must be addressed first, as the open forwarding posture amplifies every host-level finding. With unrestricted inter-zone access, vulnerabilities such as anonymous FTP and cleartext credentials are reachable by any device on the network. Closing the firewall gaps does not eliminate the host-level risks, but it reduces the attack surface while host remediations are scheduled.

- **FW1 / FW2** — Set default DROP policy on INPUT and FORWARD chains; implement explicit allow rules by port and protocol. These two items must be addressed together in a single change window, as partial implementation may break legitimate traffic.
- **FW3** — Implement stateful connection tracking (ESTABLISHED, RELATED) on the FORWARD chain. Depends on FW1/FW2 being in place first, as stateful rules only function correctly when the default policy is DROP.
- **FW4** — Restrict SSH and Webmin to the management interface (eth0) only. Recommended to address in the same session as FW1–FW3 to avoid being locked out mid-change.
- **F1** — Disable anonymous FTP login on the Ubuntu server. No technical dependencies, but should be addressed in the same window as FW1–FW4 given the active data exposure risk. Review the contents of the `confidential` directory immediately for potential HIPAA breach assessment.
- **F2** — Enforce HTTPS on the Ubuntu web application and replace the Werkzeug development server with a production WSGI stack. No dependencies, but bundles naturally with F1 as both are Ubuntu-side remediations.
- **F3** — Enforce AUTH TLS on the FTP service, or migrate file transfer to SFTP. Dependent on F1: removing anonymous access without enforcing encrypted auth for authenticated sessions leaves credential exposure in place. Both must be closed to fully remediate

the FTP service.

Short-Term Window (8–30 Days)

The following two findings affect the Windows server and are best addressed in a single dedicated Windows hardening pass. No dependencies exist between F4 and F5, but scheduling them together minimizes maintenance windows and allows for coordinated testing.

- **F4** — Disable TLS 1.0 and 1.1 on the RDP service via registry or Group Policy. Also evaluate whether RDP requires broad network access or can be restricted to specific management IP addresses.
- **F5** — Restrict port 135 (RPC endpoint mapper) to trusted management addresses via firewall rules. Evaluate whether the Print Spooler service is required on this host; if not, disable it to eliminate a well-documented attack surface.

Long-Term Window (31–90 Days)

The following items carry low standalone risk and can be addressed opportunistically during scheduled maintenance cycles. No inter-dependencies exist between F6, F7, and F8.

- **F6** — Remove weak SSH MAC algorithms (`umac-64-etm`, `umac-64`) from the SSH configuration on both the Ubuntu and Windows servers. A five-minute configuration change on each host.
- **F7** — Suppress TCP timestamp responses on both Ubuntu and Windows to reduce uptime-based reconnaissance data available to an attacker.
- **F8** — Block ICMP Type 13 (timestamp) replies at the firewall or on the Ubuntu host directly. Lowest-priority finding in the assessment.

1.3 Timeframe Summary

ID	Finding	Timeframe	Depends On	System
FW1	Default ACCEPT policy — all chains	Immediate	FW2 (pair)	Router (192.168.56.106)
FW2	Unrestricted inter-zone forwarding	Immediate	FW1 (pair)	Router (192.168.56.106)
FW3	No stateful connection tracking	Immediate	FW1, FW2	Router (192.168.56.106)
FW4	Management services on all interfaces	Immediate	FW1–FW3	Router (192.168.56.106)
F1	Anonymous FTP — confidential directory exposed	Immediate	None	Ubuntu (192.168.56.102)
F2	Cleartext HTTP credential transmission	Immediate	None	Ubuntu (192.168.56.102)
F3	FTP authenticated sessions over cleartext	Immediate	F1	Ubuntu (192.168.56.102)
F4	Deprecated TLS 1.0/1.1 on RDP	Short-Term	None	Windows (192.168.56.105)
F5	DCE/RPC endpoint enumeration	Short-Term	None	Windows (192.168.56.105)
F6	Weak SSH MAC algorithms	Long-Term	None	Ubuntu, Windows
F7	TCP timestamp disclosure	Long-Term	None	Ubuntu, Windows

ID	Finding	Timeframe	Depends On	System
F8	ICMP timestamp reply	Long-Term	None	Ubuntu (192.168.56.102)

2 Remediation Details

2.1 Firewall Hardening (FW1–FW4)

Immediate **System:** Router (192.168.56.106) **Service Impact:** Brief — seconds of dropped traffic during flush

Background

The router currently has a default ACCEPT policy on all three chains with no stateful inspection and unrestricted forwarding between zones. Management services (SSH on port 22, Webmin on port 10000) are bound to all interfaces. The following steps implement a default-deny posture with explicit allow rules matching the proposed ruleset from D2.

Step 1 — Install persistence package

Before modifying any rules, install `iptables-persistent` so the ruleset survives reboots. Answer **Yes** to both prompts to save current rules (even though we are about to replace them).

```
apt-get update && apt-get install -y iptables-persistent
```

Step 2 — Flush existing rules and set default DROP

```
# Flush all existing rules

iptables -F

iptables -X

iptables -t nat -F

iptables -t nat -X


# Set default DROP on INPUT and FORWARD; OUTPUT remains ACCEPT

iptables -P INPUT DROP

iptables -P FORWARD DROP

iptables -P OUTPUT ACCEPT
```

Warning: After setting INPUT to DROP, new SSH sessions from untrusted interfaces will be blocked immediately. Ensure you are connected via eth0 (management side) before proceeding, or have console access as a fallback.

Step 3 — INPUT chain rules (traffic destined for the router)

```
# Allow loopback

iptables -A INPUT -i lo -j ACCEPT


# Allow SSH from management interface (eth0) only

iptables -A INPUT -i eth0 -p tcp --dport 22 -j ACCEPT


# Allow ICMP (ping / diagnostics) from management interface

iptables -A INPUT -i eth0 -p icmp -j ACCEPT


# Allow established and related connections initiated by the router

iptables -A INPUT -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT
```

Step 4 — FORWARD chain rules (traffic passing between zones)

```
# Allow established and related forwarded connections (stateful tracking)
iptables -A FORWARD -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT

# Allow HTTP from scan-net (eth0) to target-net (eth1)
iptables -A FORWARD -i eth0 -o eth1 -p tcp --dport 80 -j ACCEPT

# Allow HTTPS from scan-net to target-net
iptables -A FORWARD -i eth0 -o eth1 -p tcp --dport 443 -j ACCEPT

# Allow SSH from scan-net to target-net
iptables -A FORWARD -i eth0 -o eth1 -p tcp --dport 22 -j ACCEPT

# Allow ICMP from scan-net to target-net
iptables -A FORWARD -i eth0 -o eth1 -p icmp -j ACCEPT

# Block all outbound traffic initiated from target-net
iptables -A FORWARD -i eth1 -o eth0 -j DROP
```

Step 5 — Restrict Webmin to management interface

Webmin binds to all interfaces by default. Edit its configuration to restrict it to the eth0 address only.

```
# Edit /etc/webmin/miniserv.conf
# Find or add the 'bind' directive and set it to the eth0 IP
bind=192.168.56.106

# Restart Webmin to apply
systemctl restart webmin
```

Step 6 — Persist the ruleset

```
# Save rules to the persistence files
netfilter-persistent save

# Verify the files were written
cat /etc/iptables/rules.v4
```

The `netfilter-persistent` service is enabled by default after installation and will reload these rules automatically on boot.

Impact / Downtime: The flush and policy change in Step 2 causes a brief interruption (typically under five seconds) to any active forwarded connections. SSH sessions to the router itself are not interrupted if the administrator is connected via `eth0`. Webmin will be unreachable from `eth1` after Step 5; this is intentional.

Verification:

```
# Confirm default policies are DROP on INPUT and FORWARD
iptables -L -n -v | grep -E "Chain (INPUT|FORWARD|OUTPUT)"

# From the Kali machine, confirm blocked services no longer respond
# (RDP, SMB, MySQL, FTP, SMTP, RPC, WinRM should all be filtered)
nmap -sV 192.168.56.0/24

# Confirm HTTP and SSH still flow to target hosts
curl -I http://192.168.56.102
ssh user@192.168.56.105
```

```
# Confirm Webmin is no longer reachable from eth1
curl -k https://192.168.56.106:10000 # should time out from target-net
side

# Confirm rules persist after reboot
reboot

iptables -L -n -v # re-run after restart; rules should be identical
```

2.2 F1 — Anonymous FTP Login

Immediate **System:** Ubuntu (192.168.56.102) **Service Impact:** FTP service restart required — seconds of downtime

Background

The vsftpd service accepts `anonymous` and `ftp` as valid usernames with no password verification, exposing a directory explicitly named `confidential`. This requires zero credentials to exploit. Before remediating, the contents of the `confidential` directory must be reviewed for PHI or sensitive data to assess whether a HIPAA breach notification obligation exists.

Step 1 — Audit the confidential directory before making changes

```
# Review what is currently exposed
ftp 192.168.56.102

# Login: anonymous / (blank password)
ls confidential/
```

Document all files present and escalate to MedTech's privacy officer if any patient records,

billing data, or identifiable health information is found.

Step 2 — Disable anonymous login in vsftpd

```
# Edit the vsftpd configuration file
nano /etc/vsftpd.conf

# Locate and set the following directives:
anonymous_enable=NO
no_anon_password=NO      # ensure this is not overriding the above

# Save and restart the service
systemctl restart vsftpd
```

Step 3 (Optional) — Disable FTP entirely if SFTP is sufficient

If file transfer can be handled over the existing SSH service, the cleanest remediation is to disable vsftpd altogether and use SFTP, which is built into OpenSSH and requires no additional configuration.

```
systemctl stop vsftpd
systemctl disable vsftpd
```

Impact / Downtime: Restarting vsftpd interrupts active FTP transfers for a few seconds. Any users or automated processes currently relying on anonymous FTP access will lose that access immediately and permanently. If any legitimate workflows depend on anonymous FTP, they must be identified and migrated to authenticated access before this change is applied.

Verification:

```
# Attempt anonymous login --- should be rejected
ftp 192.168.56.102
# Enter: anonymous / (blank)
# Expected: "530 Login incorrect" or "530 Permission denied"

# Confirm with nmap that FTP is still up (if not disabled) but anonymous
# login is blocked
nmap -sV -p 21 --script ftp-anon 192.168.56.102
# Expected output: "Anonymous FTP login allowed: false"
```

2.3 F2 — Cleartext HTTP Credential Transmission

Immediate **System:** Ubuntu (192.168.56.102) **Service Impact:** Web application restart required — brief downtime

Background

The login form at <http://192.168.56.102/login> transmits credentials over plain HTTP. Any device on the same network segment can intercept these credentials passively. The application is currently being served by Werkzeug, a Python development framework not intended for production use. This remediation focuses on enforcing TLS; migration away from Werkzeug is noted as a required follow-on task.

Step 1 — Generate a TLS certificate

For an internal network, a self-signed certificate is acceptable as an immediate fix. A CA-signed certificate should be obtained before any internet-facing deployment.


```
# Generate a self-signed certificate valid for 365 days
openssl req -x509 -newkey rsa:4096 -keyout /etc/ssl/private/medtech.key \
    -out /etc/ssl/certs/medtech.crt -days 365 -nodes \
    -subj "/CN=192.168.56.102/O=MedTech Solutions"

# Set correct permissions on the private key
chmod 600 /etc/ssl/private/medtech.key
```

Step 2 — Enable TLS in the Werkzeug application

Locate the section of the application code where the Werkzeug development server is started (typically a call to `app.run()`) and add the `ssl_context` parameter.

```
# In the Flask/Werkzeug application entry point (e.g. app.py):
app.run(
    host='0.0.0.0',
    port=443,
    ssl_context=(
        '/etc/ssl/certs/medtech.crt',
        '/etc/ssl/private/medtech.key'
    )
)
```

Step 3 — Redirect HTTP to HTTPS

Add a redirect so that any request arriving on port 80 is automatically forwarded to the HTTPS endpoint.

```
# Add before app.run() in the application code:
from flask import redirect, request
```

```
@app.before_request
def enforce_https():
    if not request.is_secure:
        url = request.url.replace("http://", "https://", 1)
        return redirect(url, code=301)
```

Follow-on task required: Werkzeug is a development server and must not remain in production. Once TLS is enforced, the application should be migrated to a production WSGI stack. The recommended path is nginx as a reverse proxy with gunicorn as the application server. This involves installing both packages, writing an nginx **server** block that terminates TLS and proxies requests to gunicorn on localhost, and configuring a systemd service for gunicorn. This is a separate change window task.

Impact / Downtime: The application must be restarted to apply the TLS configuration change. Users with active sessions will be disconnected. After the change, browsers accessing `http://192.168.56.102` will be redirected to HTTPS; clients that have hard-coded the HTTP URL will need to update their bookmarks or configurations.

Verification:

```
# Confirm HTTPS is serving the login page
curl -k -I https://192.168.56.102/login
# Expected: HTTP/1.1 200 OK

# Confirm HTTP redirects to HTTPS
curl -I http://192.168.56.102/login
# Expected: HTTP/1.1 301 Moved Permanently
```

```
#           Location: https://192.168.56.102/login

# Confirm credentials are no longer visible in plaintext
# Run a packet capture during a login attempt and verify the
# POST body is encrypted

tcpdump -i eth0 -w /tmp/capture.pcap host 192.168.56.102

# Open in Wireshark --- login POST should appear as TLS Application Data,
# not readable form fields
```

2.4 F3 — FTP Cleartext Authentication

Immediate **System:** Ubuntu (192.168.56.102) **Service Impact:** FTP service restart required — seconds of downtime. **Depends on F1 being completed first.**

Background

Even after anonymous access is disabled (F1), authenticated FTP sessions transmit credentials in plaintext unless AUTH TLS is enforced. This finding addresses that residual exposure. The preferred remediation is to migrate to SFTP entirely; the AUTH TLS approach is provided as an alternative if FTP must be retained.

Option A (Preferred) — Migrate to SFTP

SFTP is provided natively by the OpenSSH service already running on port 22. No additional software is required. Users connect with their existing system credentials.

```
# Confirm SFTP subsystem is enabled in sshd (it is by default)

grep -i subsystem /etc/ssh/sshd_config

# Expected output: Subsystem sftp /usr/lib/openssh/sftp-server
```

```
# If the line is commented out, uncomment it and restart SSH
systemctl restart sshd

# Disable vsftpd entirely once users are migrated
systemctl stop vsftpd
systemctl disable vsftpd
```

Option B — Enforce AUTH TLS on vsftpd

If FTP must be retained, enforce TLS for all sessions. This requires the certificate generated in F2 (or a dedicated FTP certificate).

```
# Edit /etc/vsftpd.conf and add or update the following directives:
ssl_enable=YES

force_local_logins_ssl=YES
force_local_data_ssl=YES
ssl_tlsv1_2=YES
ssl_sslv2=NO
ssl_sslv3=NO
ssl_tlsv1=NO

rsa_cert_file=/etc/ssl/certs/medtech.crt
rsa_private_key_file=/etc/ssl/private/medtech.key

# Restart vsftpd
systemctl restart vsftpd
```

Impact / Downtime: Option A removes FTP entirely; any clients currently using FTP must be reconfigured to use SFTP (port 22). Most FTP clients support SFTP natively. Option B requires a vsftpd restart (seconds of downtime) and requires FTP clients to support AUTH TLS — plain FTP clients will be rejected after this change.

Verification (Option A):

```
# Confirm SFTP login succeeds with valid credentials
sftp user@192.168.56.102

# Should prompt for password and drop into an sftp> shell

# Confirm FTP port is no longer open
nmap -p 21 192.168.56.102

# Expected: 21/tcp closed ftp
```

Verification (Option B):

```
# Attempt plain FTP login --- should be rejected
ftp 192.168.56.102

# Expected: connection refused or AUTH TLS required error

# Confirm FTPS connects successfully with an AUTH TLS-capable client
lftp -u user,password -e "set ftp:ssl-force true; ls; quit" \
    192.168.56.102

# Confirm with nmap script
nmap -p 21 --script ftp-syst,ftp-anon 192.168.56.102
```

2.5 F4 — Deprecated TLS 1.0 and 1.1 on RDP

Short-Term **System:** Windows (192.168.56.105) **Service Impact:** Registry change requires reboot to take full effect

Background

The RDP service on the Windows server advertises support for TLS 1.0 and 1.1 in addition to TLS 1.2. Both older protocol versions have known cryptographic weaknesses (CVE-2011-3389, CVE-2015-0204) that can allow downgrade attacks. The fix is a set of registry changes that disable TLS 1.0 and 1.1 at the Schannel provider level, affecting all services on the host that use the Windows TLS stack.

Step 1 — Disable TLS 1.0

Open an elevated PowerShell or Command Prompt and run the following:

```
# Disable TLS 1.0 for the server role
reg add "HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\
  Protocols\TLS 1.0\Server" /v Enabled /t REG_DWORD /d 0 /f
reg add "HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\
  Protocols\TLS 1.0\Server" /v DisabledByDefault /t REG_DWORD /d 1 /f

# Disable TLS 1.0 for the client role
reg add "HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\
  Protocols\TLS 1.0\Client" /v Enabled /t REG_DWORD /d 0 /f
reg add "HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\
  Protocols\TLS 1.0\Client" /v DisabledByDefault /t REG_DWORD /d 1 /f
```

Step 2 — Disable TLS 1.1

```
# Disable TLS 1.1 for the server role
reg add "HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\
  Protocols\TLS 1.1\Server" /v Enabled /t REG_DWORD /d 0 /f
reg add "HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\
  Protocols\TLS 1.1\Server" /v DisabledByDefault /t REG_DWORD /d 1 /f

# Disable TLS 1.1 for the client role
reg add "HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\
  Protocols\TLS 1.1\Client" /v Enabled /t REG_DWORD /d 0 /f
reg add "HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\
  Protocols\TLS 1.1\Client" /v DisabledByDefault /t REG_DWORD /d 1 /f
```

Step 3 — Explicitly confirm TLS 1.2 is enabled

TLS 1.2 should be enabled by default on modern Windows Server builds, but confirm it explicitly to avoid locking out RDP connections after the reboot.

```
# Confirm TLS 1.2 is enabled for both server and client roles
reg add "HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\
  Protocols\TLS 1.2\Server" /v Enabled /t REG_DWORD /d 1 /f
reg add "HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\
  Protocols\TLS 1.2\Server" /v DisabledByDefault /t REG_DWORD /d 0 /f
reg add "HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\
  Protocols\TLS 1.2\Client" /v Enabled /t REG_DWORD /d 1 /f
reg add "HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\
  Protocols\TLS 1.2\Client" /v DisabledByDefault /t REG_DWORD /d 0 /f
```

Step 4 — Reboot

```
shutdown /r /t 60 /c "Applying TLS hardening changes"
```

Impact / Downtime: The registry changes have no immediate effect — the server must be rebooted for Schannel to pick them up. Plan a maintenance window accordingly. After the reboot, any RDP client that supports only TLS 1.0 or 1.1 will be unable to connect. All modern RDP clients (Windows 7+, Remote Desktop app on macOS/iOS/Android) support TLS 1.2 and will be unaffected.

Verification:

```
# From the Kali machine, scan the RDP port and check supported protocols
nmap -p 3389 --script rdp-enum-encryption 192.168.56.105

# Expected: TLS 1.0 and TLS 1.1 absent from results
# TLS 1.2 (or higher) should be the only negotiated protocol

# Alternatively, use testssl.sh against port 3389:
testssl.sh --protocols 192.168.56.105:3389

# Expected: TLSv1 and TLSv1.1 listed as "not offered"
```

2.6 F5 — DCE/RPC Endpoint Enumeration

Short-Term **System:** Windows (192.168.56.105) **Service Impact:** Firewall rule change only — no service restart required

Background

Port 135 (Microsoft RPC endpoint mapper) is responding to enumeration queries and re-

turning a full list of active RPC services including `lsass.exe`, `spoolsv.exe`, and Windows Event Log endpoints. This information assists an attacker in identifying specific targets for privilege escalation or lateral movement. The Print Spooler service in particular has a well-documented history of critical exploits. The fix has two components: restrict port 135 to trusted addresses, and evaluate whether the Print Spooler service is needed on this host.

Step 1 — Restrict port 135 via Windows Firewall

Run the following in an elevated PowerShell session:

```
# Block inbound RPC endpoint mapper from all addresses
New-NetFirewallRule -DisplayName "Block RPC Endpoint Mapper" `
    -Direction Inbound `
    -Protocol TCP `
    -LocalPort 135 `
    -Action Block

# If a specific management IP needs RPC access, add an allow rule
# with higher priority (lower number = higher priority)
New-NetFirewallRule -DisplayName "Allow RPC from Management" `
    -Direction Inbound `
    -Protocol TCP `
    -LocalPort 135 `
    -RemoteAddress 192.168.56.103 `
    -Action Allow `
    -Priority 1
```

Step 2 — Evaluate and disable the Print Spooler service

If this server does not perform printing functions, the Print Spooler service should be disabled. It is a recurring target for privilege escalation exploits (including PrintNightmare,

CVE-2021-34527).

```
# Check if the Spooler service is running

Get-Service -Name Spooler


# If not needed, stop and disable it

Stop-Service -Name Spooler -Force

Set-Service -Name Spooler -StartupType Disabled
```

Impact / Downtime: The firewall rule change takes effect immediately with no reboot required. Blocking port 135 has no impact on normal user workflows unless a management tool relies on DCOM or WMI over RPC from a non-whitelisted address — confirm this before applying. Disabling the Print Spooler removes all printing capability from the server; verify no print queues or shared printers depend on this host before disabling.

Verification:

```
# From the Kali machine, confirm port 135 no longer responds to enumeration
nmap -p 135 --script msrpc-enum 192.168.56.105

# Expected: port 135 filtered or enumeration returns no results


# Confirm the Spooler service is stopped (if disabled)

# Run on the Windows host:

Get-Service -Name Spooler

# Expected: Status = Stopped, StartType = Disabled
```

2.7 F6 — Weak SSH MAC Algorithms

Long-Term **System:** Ubuntu (192.168.56.102) and Windows (192.168.56.105) **Service Impact:** SSH service restart required on each host — seconds of downtime

Background

Both SSH servers advertise support for `umac-64-etm@openssh.com` and `umac-64@openssh.com` — 64-bit MAC algorithms considered cryptographically weak by current standards. The fix is a one-line configuration change on each host to restrict the advertised MAC list to strong algorithms only.

Ubuntu (192.168.56.102)

```
# Edit the SSH server configuration
nano /etc/ssh/sshd_config

# Add or update the MACs directive to allow only strong algorithms:
MACs hmac-sha2-256-etm@openssh.com,hmac-sha2-512-etm@openssh.com,hmac-sha2-256,hmac-sha2-512

# Validate the configuration before restarting
sshd -t

# Expected: no output (no errors)

# Restart the SSH service
systemctl restart sshd
```

Windows (192.168.56.105)

OpenSSH for Windows stores its configuration at `C:\ProgramData\ssh\sshd_config`.

```
# Open the configuration file in an elevated text editor
notepad C:\ProgramData\ssh\sshd_config

# Add or update the MACs directive:
MACs hmac-sha2-256-etm@openssh.com,hmac-sha2-512-etm@openssh.com,hmac-sha2
    -256,hmac-sha2-512

# Restart the OpenSSH server service
Restart-Service sshd
```

Impact / Downtime: Each SSH service restart disconnects active sessions for a few seconds. After the change, SSH clients that support only `umac-64` MACs will be unable to connect; this is unlikely in practice as all modern OpenSSH clients (version 6.9+) support `hmac-sha2-256` and `hmac-sha2-512`.

Verification:

```
# From the Kali machine, check the advertised MAC algorithms on each host
nmap -p 22 --script ssh2-enum-algos 192.168.56.102
nmap -p 22 --script ssh2-enum-algos 192.168.56.105

# In both outputs, confirm:
# - umac-64-etm@openssh.com is ABSENT from the mac_algorithms list
# - umac-64@openssh.com is ABSENT from the mac_algorithms list
# - hmac-sha2-256 and/or hmac-sha2-512 are PRESENT

# Confirm SSH login still works after the change
ssh user@192.168.56.102
ssh user@192.168.56.105
```

3 Compensating Controls

Compensating controls are interim measures applied when a finding cannot be fully remediated immediately. They do not replace the fixes described in Section 2 — they reduce exposure in the time between discovery and resolution. Each control in this section is implementable using tools and capabilities already present on the MedTech network, requiring no new hardware or software procurement.

Controls are organized by the system or finding they address. Where a finding has both a compensating control and a dependency on another finding, the dependency is noted.

Note on the EHR server: The Ubuntu application server (192.168.56.102) is treated throughout this section as the legacy EHR host. In a healthcare environment, changes to an EHR system — even configuration changes to adjacent services — often require

vendor coordination, change freeze compliance, or scheduled downtime windows. The compensating controls for Ubuntu-hosted findings are written with that constraint in mind: they harden the environment around the EHR server without touching the server itself.

3.1 Firewall Gaps (FW1–FW4): Before Hardening Is Applied

Immediate **System:** Router (192.168.56.106) **Applies until:** Full firewall hardening from Section 2 is implemented

Situation

Until the iptables ruleset is replaced, the router forwards all traffic between zones with no filtering and no stateful tracking. Every host-level vulnerability on the network is reachable from any device on either interface. The compensating controls here aim to reduce that exposure at the service level on each host while the maintenance window for the firewall change is arranged.

Control 1 — Enable packet logging on the router

With default ACCEPT policies in place, adding a logging rule before the ACCEPT default gives visibility into traffic that would otherwise pass silently. This does not block anything but creates an audit trail and can surface unexpected access attempts.

```
# Log all inbound traffic not matched by an explicit rule
# Insert at the end of the INPUT chain
iptables -A INPUT -j LOG --log-prefix "FW-INPUT-UNMATCHED: " --log-level 4

# Log all forwarded traffic
iptables -A FORWARD -j LOG --log-prefix "FW-FORWARD-UNMATCHED: " \
```

```
--log-level 4

# Logs will appear in the kernel log, readable via:
tail -f /var/log/kern.log | grep "FW-"
```

Control 2 — Restrict Webmin access at the service level

Even before the full firewall hardening is applied, Webmin can be restricted to the management interface immediately by editing its configuration. This closes the most dangerous management exposure without touching iptables.

```
# Edit /etc/webmin/miniserv.conf
# Add or update the bind directive:
bind=192.168.56.106

# Restart Webmin
systemctl restart webmin
```

Control 3 — Monitor active connections on the router

Periodically review what connections are passing through the router to identify unexpected traffic patterns before the full ruleset is in place.

```
# View active forwarded connections
conntrack -L

# Watch for new connections in real time
conntrack -E

# Check which processes are listening on all interfaces
ss -tulnp
```

Limitation: These controls provide visibility and reduce the Webmin exposure but do not substitute for the default DROP policy and explicit forwarding rules described in Section 2. Anonymous FTP, cleartext HTTP, and RDP with deprecated TLS remain accessible from the scan network until the full firewall hardening is applied.

3.2 F1 and F3: Anonymous FTP and Cleartext FTP Auth

Immediate **System:** Ubuntu EHR server (192.168.56.102), port 21 **Applies until:** Anonymous access is disabled and SFTP migration or AUTH TLS enforcement is complete

Situation

Anonymous FTP access to a directory named **confidential** represents the single highest-priority data exposure risk in the assessment. If a change freeze or EHR vendor coordination requirement prevents immediate modification of the vsftpd configuration, the following controls reduce the risk of exploitation and establish an audit trail while the fix is being scheduled.

Control 1 — Block FTP at the router before the host fix is applied

If the firewall hardening from Section 2 cannot be applied immediately either, a targeted rule blocking port 21 at the router provides an interim layer of protection for this specific service without modifying the EHR server itself.

```
# On the router: block inbound FTP to the Ubuntu server
# This can be applied even before the full firewall hardening
iptables -I FORWARD -p tcp -d 192.168.56.102 --dport 21 -j DROP
```



```
# Log dropped FTP attempts for the audit trail
iptables -I FORWARD -p tcp -d 192.168.56.102 --dport 21 \
-j LOG --log-prefix "FTP-BLOCKED: " --log-level 4
```

Important: This rule blocks FTP access to the Ubuntu server from the network but does not prevent local access from the server itself or from any host on the same subnet that bypasses the router. It is a layer of defense-in-depth, not a complete fix. The vsftpd configuration must still be corrected per Section 2.

Control 2 — Enable FTP access logging on the Ubuntu server

If the vsftpd configuration cannot be changed immediately, enable verbose logging to capture all anonymous access attempts and file activity. This creates an audit record and supports any HIPAA breach assessment that may be required.

```
# Edit /etc/vsftpd.conf and confirm or add the following:
xferlog_enable=YES
xferlog_std_format=NO
log_ftp_protocol=YES
vsftpd_log_file=/var/log/vsftpd.log

# Restart vsftpd to apply logging changes only
systemctl restart vsftpd

# Monitor the log in real time
tail -f /var/log/vsftpd.log
```

Control 3 — Audit and relocate the confidential directory

While the access control fix is being scheduled, immediately audit the contents of the

`confidential` directory and move any sensitive files to a location not served by `vsftpd`. This does not require a service restart.

```
# Review the current contents
ls -la /home/ftp/confidential/    # adjust path to match actual vsftpd root

# Move sensitive files out of the FTP-served directory
mv /home/ftp/confidential/* /root/confidential_archive/

# Confirm the directory now appears empty to anonymous users
ftp 192.168.56.102

# Login: anonymous
# ls confidential/
# Expected: empty directory listing
```

3.3 F2: Cleartext HTTP Credential Transmission

Immediate **System:** Ubuntu EHR server (192.168.56.102), port 80 **Applies until:**
TLS is enforced on the web application per Section 2

Situation

The web login page transmits credentials in plaintext over HTTP. Until TLS is enforced, the primary compensating control is to limit which hosts can reach the login page at all, and to monitor for credential interception attempts on the network segment.

Control 1 — Restrict HTTP access to authorized hosts only

Using the router, limit which source addresses can reach port 80 on the Ubuntu server. This

does not encrypt the traffic but significantly reduces the number of hosts that could intercept credentials.

```
# On the router: allow HTTP to the Ubuntu server only from
# known authorized addresses (adjust the source IP as needed)
iptables -I FORWARD -p tcp -d 192.168.56.102 --dport 80 \
-s 192.168.56.103 -j ACCEPT

# Block HTTP from all other sources
iptables -I FORWARD -p tcp -d 192.168.56.102 --dport 80 -j DROP

# Log blocked attempts
iptables -I FORWARD -p tcp -d 192.168.56.102 --dport 80 \
-j LOG --log-prefix "HTTP-BLOCKED: " --log-level 4
```

Control 2 — Monitor for credential interception on the network

From the Kali management machine, run a passive packet capture on the subnet during business hours to detect whether any host is intercepting credentials in transit. This is a monitoring control — it does not prevent interception but provides evidence if it occurs.

```
# On the Kali machine: capture HTTP traffic on the network segment
# and filter for POST requests (which carry login credentials)
tcpdump -i eth0 -A 'tcp port 80 and (tcp[((tcp[12:1] & 0xf0) >> 2):4] \
= 0x504f5354)' -w /tmp/http_capture.pcap

# Review the capture for any plaintext credential fields
strings /tmp/http_capture.pcap | grep -iE "password|passwd|pwd|login"
```

Limitation: Restricting access by source IP (Control 1) reduces exposure but does not eliminate it — a compromised authorized host, or an attacker who spoofs an authorized address on the local segment, could still intercept credentials. TLS enforcement per Section 2 is the only complete fix.

3.4 F4: Deprecated TLS on RDP

Short-Term **System:** Windows server (192.168.56.105), port 3389 **Applies until:** TLS 1.0 and 1.1 are disabled via registry per Section 2

Situation

The registry fix for this finding requires a reboot, which may need to be scheduled during a maintenance window. In the meantime, the primary risk is that an attacker on the network could downgrade an RDP session to TLS 1.0 or 1.1 and decrypt the traffic. The compensating control is to restrict which hosts can initiate RDP connections at all, reducing the opportunity for a downgrade attack.

Control 1 — Restrict RDP access to the management host only

```
# On the router: allow RDP only from the Kali management machine
iptables -I FORWARD -p tcp -d 192.168.56.105 --dport 3389 \
-s 192.168.56.103 -j ACCEPT

# Block RDP from all other sources
iptables -I FORWARD -p tcp -d 192.168.56.105 --dport 3389 -j DROP

# Log blocked RDP attempts
iptables -I FORWARD -p tcp -d 192.168.56.105 --dport 3389 \
```

```
-j LOG --log-prefix "RDP-BLOCKED: " --log-level 4
```

Control 2 — Restrict RDP on the Windows host itself

As a second layer, use Windows Firewall to enforce the same restriction locally on the host. This ensures the control holds even if the router rules are not yet in place.

```
# In an elevated PowerShell session on the Windows server:

# Remove any existing broad RDP allow rules
Get-NetFirewallRule -DisplayName "*Remote Desktop*" | '
    Where-Object { $_.Action -eq "Allow" } | Remove-NetFirewallRule

# Add a targeted allow rule for the management host only
New-NetFirewallRule -DisplayName "RDP - Management Only" '
    -Direction Inbound '
    -Protocol TCP '
    -LocalPort 3389 '
    -RemoteAddress 192.168.56.103 '
    -Action Allow

# Confirm the rule is active
Get-NetFirewallRule -DisplayName "RDP - Management Only"
```

Control 3 — Monitor RDP connection attempts

Enable logging of RDP connection attempts on the Windows server so that any unauthorized access attempts during the remediation window are captured in the event log.

```
# Enable audit logging for logon events in an elevated PowerShell session
auditpol /set /subcategory:"Logon" /success:enable /failure:enable
```

```
# Review recent RDP logon events (Event ID 4624 = success, 4625 = failure)
Get-WinEvent -FilterHashtable @{'LogName='Security'; Id=4624,4625} '
    | Select-Object TimeCreated, Message | Format-List
```

3.5 F5: DCE/RPC Endpoint Enumeration

Short-Term **System:** Windows server (192.168.56.105), port 135 **Applies until:** Port 135 is restricted and Print Spooler is evaluated per Section 2

Situation

Port 135 is currently responding to enumeration queries from any host on the network, returning a map of internal RPC services including security and print management processes. Until the firewall rule restricting port 135 is applied, the compensating control is to limit network access to port 135 and monitor for enumeration activity.

Control 1 — Block port 135 at the router

```
# On the router: block RPC endpoint mapper access from the scan network
iptables -I FORWARD -p tcp -d 192.168.56.105 --dport 135 -j DROP

# Log blocked attempts to detect active enumeration
iptables -I FORWARD -p tcp -d 192.168.56.105 --dport 135 \
    -j LOG --log-prefix "RPC-BLOCKED: " --log-level 4
```

Control 2 — Disable the Print Spooler service immediately

Unlike the firewall rule for port 135, disabling the Print Spooler requires no reboot and no maintenance window. If printing is not required on this host, this is a zero-downtime hardening action that can be taken immediately regardless of the broader remediation schedule.

```
# In an elevated PowerShell session on the Windows server:

Stop-Service -Name Spooler -Force

Set-Service -Name Spooler -StartupType Disabled

# Confirm

Get-Service -Name Spooler

# Expected: Status = Stopped, StartType = Disabled
```

Note: Disabling the Print Spooler is listed here as a compensating control because it can be done immediately, but it is also the permanent remediation for that specific exposure. Applying it now does not remove the need to restrict port 135 via the firewall rule in Section 2 — the RPC endpoint mapper will still advertise other services until that rule is in place.

3.6 Summary of Compensating Controls

The table below maps each compensating control to the finding it addresses, the mechanism used, and the condition under which it can be retired in favor of the full remediation from Section 2.

ID	Control	Mechanism	Retire when...
FW1– 4	Packet logging on router	iptables rules	LOG Full hardening rule- set applied

ID	Control	Mechanism	Retire when...
FW4	Restrict Web-min to eth0	miniserv.conf bind directive	Firewall rule restricts port 10000
F1, F3	Block port 21 at router	iptables FOR-WARD DROP	Anonymous FTP disabled on host
F1, F3	Enable vsftpd verbose logging	vsftpd.conf xferlog directives	FTP service disabled or SFTP migrated
F1, F3	Relocate confidential directory	confidential directory mv command	Filesystem — Access controls confirmed in place
F2	Restrict HTTP to authorized hosts	iptables FOR-WARD source filter	TLS enforced on web application
F2	Passive credential monitoring	tcpdump on Kali management host	TLS enforced on web application
F4	Restrict RDP at router and host	iptables + Windows Firewall rule	TLS 1.0/1.1 disabled via registry
F4	Enable RDP logon auditing	Windows auditpol / Event Log	Can remain as permanent monitoring
F5	Block port 135 at router	iptables FOR-WARD DROP	Windows Firewall rule applied

ID	Control	Mechanism	Retire when...
F5	Disable Print Spooler	Windows service — PowerShell	Permanent — no retirement needed

4 Compliance Mapping

This section maps each finding and its remediation to the relevant HIPAA Security Rule Technical Safeguard standards under 45 CFR §164.312. It then provides a Q3 audit readiness checklist organized by safeguard, and describes the documentation MedTech should collect and retain to demonstrate compliance progress to an auditor.

Scope note: The HIPAA Security Rule Technical Safeguards apply to electronic protected health information (ePHI). MedTech’s compliance obligation exists regardless of whether ePHI was confirmed in any specific directory or log at the time of this assessment. The presence of a system capable of storing or transmitting ePHI is sufficient to trigger the safeguard requirements. The Ubuntu EHR server and the Windows IIS server are both in scope.

4.1 HIPAA Technical Safeguards Reference

The five Technical Safeguard standards under 45 CFR §164.312 are summarized below for reference. Required implementation specifications are marked **(R)**; addressable specifications are marked **(A)**.

CFR	Standard	Spec.	Requirement
(a)(1)	Access Control	Unique User ID (R)	Each user must have a unique name or number for identifying and tracking identity.
(a)(1)	Access Control	Automatic Logoff (A)	Implement electronic procedures to terminate a session after a period of inactivity.
(a)(1)	Access Control	Encryption/Decryption (A)	Implement a mechanism to encrypt and decrypt ePHI.
(a)(2)	Audit Controls	(no sub-specs) (R)	Implement hardware, software, or procedural mechanisms to record and examine activity in systems that contain ePHI.
(b)	Integrity	Authentication Mechanism (A)	Implement electronic mechanisms to corroborate that ePHI has not been altered or destroyed in an unauthorized manner.
(c)	Person or Entity Authentication	(no sub-specs) (R)	Implement procedures to verify that a person or entity seeking access to ePHI is who they claim to be.

CFR	Standard	Spec.	Requirement
(e)(1)	Transmission Security	Integrity Controls (A)	Implement security measures to ensure that electronically transmitted ePHI is not improperly modified without detection.
(e)(1)	Transmission Security	Encryption (A)	Implement a mechanism to encrypt ePHI in transit whenever deemed appropriate.

4.2 Finding-to-Safeguard Mapping

The table below maps each finding from the assessment to the HIPAA Technical Safeguard standard it implicates, with a brief rationale. Findings that implicate multiple standards are listed once per standard.

ID	Finding	Safeguard	Rationale
FW1-Default 2	ACCEPT, unrestricted forwarding	(a)(1) Access Control	No perimeter controls means no enforceable access restrictions on any ePHI-hosting system.

ID	Finding	Safeguard	Rationale
FW3-4	No stateful inspection; management services exposed	(a)(1) Access Control	Absence of stateful tracking and unrestricted management access undermine the ability to enforce unique user access controls at the network layer.
F1	Anonymous FTP — confidential directory exposed	(a)(1) Access Control	Anonymous access with no credentials is a direct violation of the unique user ID requirement — there is no identity to track.
F1	Anonymous FTP — confidential directory exposed	(a)(2) Audit Controls	Anonymous sessions produce no user-attributable audit record, making it impossible to determine who accessed the confidential directory or what was downloaded.

ID	Finding	Safeguard	Rationale
F2	Cleartext HTTP credential transmission	(c) Authentication	Credentials transmitted in plaintext can be intercepted and replayed, undermining the authentication mechanism entirely.
F2	Cleartext HTTP credential transmission	(e)(1) Transmission	Login credentials — and any ePHI accessible post-login — travel over the network unencrypted and are subject to passive interception.
F3	FTP cleartext authentication	(c) Authentication	FTP credentials transmitted in plaintext are subject to the same interception risk as HTTP credentials, invalidating the authentication mechanism for any user accessing the FTP service.

ID	Finding	Safeguard	Rationale
F3	FTP cleartext authentication	(e)(1) Transmission	Authenticated FTP sessions transmit both credentials and file contents without encryption, exposing any ePHI transferred via FTP.
F4	Deprecated TLS 1.0/1.1 on RDP	(e)(1) Transmission	Deprecated TLS versions have known cryptographic weaknesses enabling downgrade attacks, meaning the encryption protecting RDP sessions may not be effective.
F5	DCE/RPC endpoint enumeration	(a)(1) Access Control	Exposing a map of internal services — including the security authority process — directly facilitates targeted access control bypass attempts.

ID	Finding	Safeguard	Rationale
F6	Weak SSH MAC algorithms	(e)(1) Transmission	64-bit MAC algorithms provide insufficient integrity assurance for administrative sessions that may involve ePHI systems.

4.3 Q3 Audit Readiness Checklist

The following checklists are organized by HIPAA Technical Safeguard standard. Each item represents a condition an OCR auditor would verify, framed as a yes/no question MedTech can use for self-assessment before Q3. Items marked **(R)** are required implementation specifications and carry no flexibility in interpretation; items marked **(A)** are addressable and require either implementation or documented justification for an alternative measure.

(a)(1) Access Control

- ☐ **(R)** Has anonymous access been disabled on all services running on ePHI-hosting systems? (FTP anonymous login removed on Ubuntu)
- ☐ **(R)** Can every account that accesses ePHI systems be traced to a unique, identified user? (No shared or anonymous accounts)
- ☐ **(R)** Are access controls in place at the network perimeter restricting which hosts can reach ePHI systems? (Firewall default DROP policy and explicit allow rules implemented)
- ☐ **(R)** Are management interfaces (SSH, Webmin) restricted to authorized management

hosts only and not exposed to the broader network?

- ☐ (A) Is there a documented procedure for granting and revoking access to ePHI systems, and has it been followed for all current accounts?
- ☐ (A) Are inactive or unnecessary accounts disabled on the Ubuntu and Windows servers?

(a)(2) Audit Controls

- ☐ (R) Are access logs enabled and actively collecting on the Ubuntu EHR server? (vsftpd logs, Apache/application logs, auth logs in /var/log/)
- ☐ (R) Are access logs enabled on the Windows server? (Windows Event Log — Security channel, IIS access logs)
- ☐ (R) Are firewall logs collecting on the router? (iptables LOG rules capturing unmatched traffic)
- ☐ (R) Are logs being reviewed on a defined schedule rather than only reactively? (Evidence of periodic review, even if informal)
- ☐ (R) Is there a log retention policy in place? Logs must be retained long enough to support breach investigation — HHS guidance suggests a minimum of six years for Security Rule documentation.
- ☐ (R) If the confidential FTP directory was accessible prior to remediation, has a log review been conducted to assess what was accessed and by whom? (HIPAA breach assessment may be required)

(b) Integrity

- ☐ (A) Are file transfer services configured to prevent unauthorized modification or deletion of ePHI? (FTP write permissions reviewed; anonymous upload disabled)
- ☐ (A) Is there a mechanism to detect whether files in the EHR system have been altered or deleted without authorization? (File integrity monitoring, even a scheduled hash check, satisfies this)
- ☐ (A) Are backup procedures in place for the Ubuntu EHR server that would allow recovery in the event of unauthorized modification?

(c) Person or Entity Authentication

- ☐ (R) Are all login pages and services that provide access to ePHI systems transmitting credentials over encrypted channels? (HTTPS enforced on web application; FTP credentials protected by AUTH TLS or SFTP migration)
- ☐ (R) Have default or vendor-supplied credentials been changed on all systems? (Ubuntu, Windows, router, Webmin, MySQL, vsftpd)
- ☐ (R) Is there a password policy in place for accounts on ePHI systems? (Minimum length, complexity, rotation schedule)
- ☐ (A) Has multi-factor authentication been evaluated for administrative access to the Ubuntu and Windows servers?

(e)(1) Transmission Security

- ☐ (A) Is TLS enforced on the web application login page and all pages that handle ePHI? (HTTPS with a valid certificate; HTTP redirected to HTTPS)
- ☐ (A) Has the Werkzeug development server been replaced with a production WSGI

server? (Werkzeug is not suitable for handling ePHI in a production environment)

- ☐ (A) Are FTP sessions encrypted in transit? (AUTH TLS enforced in vsftpd, or FTP replaced with SFTP)
- ☐ (A) Has support for deprecated TLS versions (1.0 and 1.1) been disabled on the Windows RDP service?
- ☐ (A) Have weak SSH MAC algorithms been removed from the SSH configuration on both the Ubuntu and Windows servers?
- ☐ (A) Is there a documented policy identifying which transmission channels carry ePHI and confirming that each is encrypted?

4.4 Documentation for Compliance Demonstration

An auditor will not take MedTech's word that remediations were applied. Every completed item needs a corresponding artifact that can be produced on request. The following describes what to collect for each finding, using tools and outputs already available in MedTech's environment.

Firewall Hardening (FW1–FW4)

- A dated screenshot or terminal capture of `iptables -L -n -v` showing default DROP policies and the explicit allow rules, taken immediately after the change.
- The contents of `/etc/iptables/rules.v4` showing the persisted ruleset.
- A dated nmap scan from the Kali machine showing the before and after state of visible ports across the subnet. The D2 report already contains the before scan; retain the after scan as the remediation artifact.
- A written record (even a dated text file) of who applied the changes and when.

F1 — Anonymous FTP

- A dated screenshot of the vsftpd.conf file showing `anonymous_enable=NO`, or confirmation that the service was disabled.
- Terminal output of a failed anonymous login attempt post-remediation (the `ftp-anon` nmap script output works well for this).
- A written record of the confidential directory audit — what files were present, who reviewed them, and the outcome of the HIPAA breach assessment. This is the most legally significant document in the entire remediation record.

F2 — Cleartext HTTP

- A dated screenshot of the TLS certificate installed on the web application (browser certificate viewer is sufficient).
- Terminal output of `curl -I http://192.168.56.102/login` showing a 301 redirect to HTTPS.
- A Wireshark or tcpdump capture showing a login POST appearing as TLS Application Data rather than readable form fields.

F3 — FTP Cleartext Auth

- If SFTP migration: terminal output of a successful SFTP login and confirmation that port 21 is closed (`nmap -p 21` output).
- If AUTH TLS: dated screenshot of the vsftpd.conf showing `ssl_enable=YES` and `force_local_logins_s` terminal output of a plain FTP connection being rejected.

F4 — Deprecated TLS on RDP

- A dated screenshot of the registry keys under `HKLM\SYSTEM\...\SCHANNEL\Protocols` showing TLS 1.0 and 1.1 disabled and TLS 1.2 enabled.
- Output of `nmap --script rdp-enum-encryption post-reboot` showing TLS 1.0 and 1.1 absent from the negotiated protocols list.

F5 — DCE/RPC Enumeration

- Output of `nmap --script msrpc-enum post-remediation` showing port 135 filtered or returning no service list.
- PowerShell output of `Get-Service -Name Spooler` confirming the Print Spooler is stopped and disabled, if that path was taken.

F6 — Weak SSH MAC Algorithms

- Dated copies of the updated `/etc/ssh/sshd_config` on Ubuntu and `C:\ProgramData\ssh\sshd_config` on Windows showing the restricted MACs directive.
- Output of `nmap --script ssh2-enum-algos` on both hosts confirming `umac-64` variants are absent from the advertised algorithm list.

Retention requirement: Under the HIPAA Security Rule, documentation of policies, procedures, and actions taken must be retained for a minimum of six years from the date of creation or the date it was last in effect, whichever is later. All artifacts collected above should be stored in a location that is itself access-controlled and backed up. A folder on the Ubuntu server is not sufficient — these records must survive the remediation of the system they document.

5 Resource Estimates

This section provides time and personnel estimates for every remediation item in this plan. Estimates cover the full scope of each work item: planning and preparation, the hands-on implementation window, post-change testing and verification, and documentation for the compliance record. All three phases are billable work and should be included in the budget.

Note for Marcus: These estimates reflect what the work requires. Whether MedTech has the internal personnel to perform each item or needs to engage outside resources is a separate determination. The skills column describes what each role involves so that determination can be made against your current team. No procurement of new hardware or software is required for any item in this plan.

5.1 How to Read These Estimates

Each remediation item is broken into three phases:

- **Planning:** Reviewing the change, coordinating the maintenance window, confirming backout procedures, and notifying affected users.
- **Implementation:** The hands-on change window — applying configuration changes, running commands, and performing the immediate smoke test.
- **Verification & Documentation:** Running the post-change verification steps from Section 2, collecting compliance artifacts per Section 4, and filing the change record.

Time estimates are given in hours and represent a realistic middle estimate — not the fastest possible execution under ideal conditions, and not a worst-case scenario. For items that require a scheduled maintenance window or system reboot, the window duration is noted separately from active working time.

5.2 Personnel Skill Requirements

Three skill profiles cover all remediation work in this plan. A single person may hold more than one profile.

Profile	What This Role Does in This Engagement
Linux Administrator	Edits configuration files on the Ubuntu server (<code>vsftpd.conf</code> , <code>sshd_config</code> , application code), manages <code>systemd</code> services, runs <code>iptables</code> commands on the router, installs <code>iptables-persistent</code> , and implements TLS on the web application. Must be comfortable working in a terminal and editing files as root.
Windows Administrator	Applies registry changes on the Windows server, manages Windows Firewall rules via PowerShell, starts and stops Windows services, and reviews Windows Event Log entries. Must be comfortable with elevated PowerShell sessions and the Windows registry editor.

Profile	What This Role Does in This Engagement
Change Co-ordinator	Schedules maintenance windows with affected teams, communicates planned downtime, collects and files compliance documentation artifacts (screenshots, terminal captures, configuration file copies), and maintains the change record. Does not require deep technical skills but must understand the scope of each change well enough to communicate it accurately.

5.3 Immediate Window Estimates (0–7 Days)

The immediate window contains the highest-priority items and the largest concentration of work. The firewall hardening and the three Ubuntu-side findings can all be addressed in a single coordinated maintenance session, but they require two personnel working in parallel or sequentially across the router and the application server.

ID	Item	Plannin	Implem	Verify & Doc	Total	Personnel
FW1-4	Firewall hard- ening	1.5 hrs	2.0 hrs	1.5 hrs	5.0 hrs	Linux Admin + Change Coordina- tor
F1	Disable anony- mous FTP; au- dit confidential directory	1.0 hrs	0.5 hrs	1.0 hrs	2.5 hrs	Linux Admin + Change Coordina- tor
F2	Enforce HTTPS on web applica- tion	1.0 hrs	1.5 hrs	1.0 hrs	3.5 hrs	Linux Admin + Change Coordina- tor
F3	Migrate FTP to SFTP or enforce AUTH TLS	0.5 hrs	1.0 hrs	0.5 hrs	2.0 hrs	Linux Admin + Change Coordina- tor
Immediate window total					13.0 hrs	

Maintenance window note: The firewall hardening (FW1–4) and the three Ubuntu-side items (F1, F2, F3) should be scheduled in the same maintenance window to minimize service disruptions. Plan for a window of approximately 4–5 hours of active work. Brief service interruptions (seconds to minutes) should be expected on FTP and the web application during this window. The confidential directory audit (F1 planning phase) should begin before the maintenance window is scheduled, as its outcome may trigger a HIPAA breach assessment that affects the overall timeline.

5.4 Short-Term Window Estimates (8–30 Days)

Both short-term items are Windows-side changes. They can be addressed in a single maintenance window on the Windows server. F4 requires a reboot; budget for a planned outage of the Windows server during this window.

ID	Item		Plannin	Implem	Verify & Doc	Total	Personnel
F4	Disable 1.0/1.1 RDP	TLS on	0.5 hrs	0.5 hrs	1.0 hrs	2.0 hrs	Windows Admin + Change Coordina- tor
F5	Restrict port 135; dis- able Spooler	RPC Print	0.5 hrs	0.5 hrs	0.5 hrs	1.5 hrs	Windows Admin + Change Coordina- tor

ID	Item	Plannin	Implem	Verify & Doc	Total	Personnel
Short-term window total					3.5 hrs	

Maintenance window note: F4 requires a reboot of the Windows server to take effect. Schedule accordingly and notify users of the planned downtime. The reboot itself takes approximately 5–10 minutes and is not included in the active working time estimates above.

5.5 Long-Term Window Estimates (31–90 Days)

The long-term item is the lowest-priority finding in the plan and can be addressed opportunistically during any scheduled maintenance cycle for either server. No downtime is required beyond a brief SSH service restart on each host.

ID	Item	Plannin	Implem	Verify & Doc	Total	Personnel
F6	Remove weak SSH MAC algorithms (both servers)	0.5 hrs	0.5 hrs	0.5 hrs	1.5 hrs	Linux Admin + Windows Admin + Change Coordinator
Long-term window total					1.5 hrs	

5.6 Werkzeug Follow-On Task

As noted in Section 2, replacing the Werkzeug development server with a production WSGI stack (nginx + gunicorn) is a required follow-on task that falls outside the immediate TLS enforcement fix. It is listed separately here because it is a more involved change than the other immediate-window items and should be scoped and scheduled as a distinct work item once the initial TLS enforcement is in place.

Item	Plannin	Implem	Verify	Total	Personnel
			& Doc		
Migrate Werkzeug to nginx + gunicorn	from 2.0 hrs	3.0 hrs	2.0 hrs	7.0 hrs	Linux Admin (with application knowledge) + Change Coordinator

Note on the Werkzeug task: This item requires the Linux Administrator to have working knowledge of the application being served — specifically how it is configured and what dependencies it has. If the person who originally deployed the Werkzeug application is not available, budget additional time for onboarding or application review before the migration begins. The 7-hour estimate assumes familiarity with the application.

5.7 Full Engagement Summary

Window	Timeline	Total Hours	Personnel Required
Immediate window (FW1–4, F1, F2, F3)	0–7 days	13.0 hrs	Linux Admin, Change Coordinator
Short-term window (F4, F5)	8–30 days	3.5 hrs	Windows Admin, Change Coordinator
Long-term window (F6)	31–90 days	1.5 hrs	Linux Admin, Windows Admin, Change Coordinator
Werkzeug follow-on	Post-immediate	7.0 hrs	Linux Admin (app knowledge), Change Coordinator
Total		25.0 hrs	

Summary for Marcus: The full remediation engagement — covering all findings across both servers, the router, and the Werkzeug follow-on — represents approximately 25 hours of skilled technical work across three personnel profiles. The most time-sensitive portion is the immediate window at 13 hours, which should be scheduled within the next 7 days given the active data exposure risks identified in this assessment. The remaining 12 hours can be distributed across the 30 and 90-day windows with minimal disruption to normal operations. No new hardware, software licenses, or infrastructure procurement

is required for any item in this plan.